

Міністерство освіти і науки України

## Дисертація

# **Методологія та інформаційна технологія захисту контекстної приватності особи в умовах інференційних загроз цифрового середовища**

на здобуття наукового ступеня доктора технічних наук

Київ – 2026

# Анотація

*Мельниченко О. <Прізвище, ініціали по батькові>. Методологія та інформаційна технологія захисту контекстної приватності особи в умовах інференційних загроз цифрового середовища – Кваліфікаційна наукова праця на правах рукопису.*

*Дисертація на здобуття наукового ступеня доктора технічних наук за спеціальністю <шифр і назва спеціальності, напр. 122 – Комп'ютерні науки / 125 – Кібербезпека та захист інформації>. – <Назва закладу>, Київ, 2026.*

*У дисертації розв'язано науково-прикладну проблему приватного контекстного захисту учасників цифрової комунікації від ризикових інформаційних впливів в умовах наскрізного шифрування та постквантового переходу. [Розгорнути: суть проблеми, основні результати, новизна, практичне значення – після написання розділів.]*

**Ключові слова:** захист контекстної приватності, оцінювання інформаційного ризику, контекстна безпека систем обміну повідомленнями, наскрізне шифрування, постквантова криптографія, OPAQUE, асиметричний парольно-автентифікований обмін ключами, ML-KEM-768, серверно-сліпий канал нагляду, захисні рішення з урахуванням політик, відтворюваність, інформаційна технологія.

# Abstract

*Melnychenko O.* Methodology and information technology for protecting a person's contextual privacy under inferential threats of the digital environment. – Qualifying scientific work on the rights of a manuscript.

Thesis for the degree of Doctor of Technical Sciences. – <Institution>, Kyiv, 2026.

The dissertation addresses the scientific and applied problem of private, context-aware protection of communication participants against harmful informational influence under end-to-end encryption and the post-quantum transition. *[To be expanded after the chapters are written.]*

**Keywords:** private contextual protection, informational risk assessment, messenger-native safety, end-to-end encryption, post-quantum cryptography, OPAQUE, augmented PAKE, ML-KEM-768, server-blind supervision relay, policy-aware safety decisions, reproducibility, information technology.

## Список публікацій здобувача за темою дисертації

1. Melnychenko O. *Hybrid PQ-OPAQUE: A Three-Message Augmented PAKE with Ephemeral ML-KEM-768* // <Journal of Information Security and Applications (подано/прийнято)>, 2026. *[уточнити статус, том, сторінки, DOI]*
2. *[додати решту публікацій за темою дисертації]*

# Зміст

|                                                                                                           |           |
|-----------------------------------------------------------------------------------------------------------|-----------|
| <b>Анотація</b>                                                                                           | <b>1</b>  |
| <b>Abstract</b>                                                                                           | <b>2</b>  |
| Список публікацій здобувача за темою дисертації . . . . .                                                 | 2         |
| <b>Перелік умовних позначень, символів і скорочень</b>                                                    | <b>7</b>  |
| <b>Вступ</b>                                                                                              | <b>9</b>  |
| <b>1 Аналіз стану проблеми захисту контекстної приватності у захищених системах обміну повідомленнями</b> | <b>14</b> |
| 1.1 Приватна цифрова комунікація та модель наскрізного шифрування                                         | 15        |
| 1.2 Ризикові інформаційні впливи в приватних каналах . . . . .                                            | 15        |
| 1.3 Дилема модерації за наскрізного шифрування . . . . .                                                  | 15        |
| 1.4 Недостатність позаконтекстної класифікації повідомлень . . .                                          | 15        |
| 1.5 Парольна автентифікація та augmented PAKE . . . . .                                                   | 15        |
| 1.6 Постквантовий перехід в автентифікації та обміні повідомленнями                                       | 15        |
| 1.7 Системи батьківського контролю та нагляду й приватність . .                                           | 15        |
| 1.8 Відтворюваність і формальна верифікація систем безпеки . . .                                          | 15        |
| 1.9 Наукова прогалина та постановка задачі . . . . .                                                      | 15        |
| Висновки до розділу 1 . . . . .                                                                           | 16        |
| <b>2 Концепція інформаційної технології на основі середовища виконання політик AURA</b>                   | <b>17</b> |
| 2.1 Середовище AURA як центральний рівень прийняття рішень .                                              | 18        |
| 2.2 Архітектурні інваріанти інформаційної технології . . . . .                                            | 20        |
| 2.3 Методологічні засади побудови інформаційної технології . . .                                          | 22        |
| 2.4 Понятійна модель контекстної приватності . . . . .                                                    | 24        |

|          |                                                                         |           |
|----------|-------------------------------------------------------------------------|-----------|
| 2.5      | Загальна архітектура AURA/Ecliptix . . . . .                            | 27        |
| 2.6      | Системні ролі та області відповідальності . . . . .                     | 28        |
| 2.7      | Довірені області та класи даних . . . . .                               | 30        |
| 2.8      | Рівні моделювання системи . . . . .                                     | 33        |
| 2.9      | Потік даних: від повідомлення до захисного рішення . . . . .            | 36        |
| 2.10     | Життєвий цикл захисного рішення . . . . .                               | 38        |
| 2.11     | Уніфікована модель загроз . . . . .                                     | 40        |
| 2.12     | Типологія інференційних загроз цифрового середовища . . . . .           | 42        |
| 2.13     | Критерії коректності системної концепції . . . . .                      | 45        |
| 2.14     | Концептуальна матриця наукової новизни . . . . .                        | 47        |
| 2.15     | Відображення «проблема – метод» . . . . .                               | 50        |
| 2.16     | Межі тверджень . . . . .                                                | 51        |
|          | Висновки до розділу 2 . . . . .                                         | 53        |
| <b>3</b> | <b>Метод контекстної оцінки інформаційного ризику</b>                   | <b>55</b> |
| 3.1      | Повідомлення як подія в контексті, а не ізольований текст . . . . .     | 55        |
| 3.2      | Контактна пам'ять . . . . .                                             | 55        |
| 3.3      | Пам'ять розмови . . . . .                                               | 55        |
| 3.4      | Часові закономірності, повторюваність та ескалація . . . . .            | 55        |
| 3.5      | Латентні стани маніпуляції (операціоналізація) . . . . .                | 55        |
| 3.6      | Доменні модулі ризику . . . . .                                         | 55        |
| 3.7      | Формування структурованого сигналу ризику . . . . .                     | 55        |
|          | Висновки до розділу 3 . . . . .                                         | 56        |
| <b>4</b> | <b>Метод прийняття рішень контекстної безпеки з урахуванням політик</b> | <b>57</b> |
| 4.1      | Перетворення сигналу ризику в захисну дію . . . . .                     | 57        |
| 4.2      | Простір рішень системи обміну повідомленнями . . . . .                  | 57        |
| 4.3      | Опрацювання невизначеності . . . . .                                    | 57        |
| 4.4      | Профіль захисту учасника та доменний режим . . . . .                    | 57        |
| 4.5      | Приватний аудиторський запис . . . . .                                  | 57        |
| 4.6      | Критерії якості з контрольованим допуском до випуску . . . . .          | 57        |
|          | Висновки до розділу 4 . . . . .                                         | 58        |
| <b>5</b> | <b>Метод постквантово-посиленої OPAQUE-автентифікації</b>               | <b>59</b> |
| 5.1      | Постановка задачі та модель загроз автентифікації . . . . .             | 60        |

|          |                                                                                               |           |
|----------|-----------------------------------------------------------------------------------------------|-----------|
| 5.2      | Архітектура трьохповідомленнєвого протоколу . . . . .                                         | 60        |
| 5.3      | Реєстрація та зв'язування ідентифікатора й контексту . . . . .                                | 60        |
| 5.4      | Гібридне DH/KEM-узгодження сесії . . . . .                                                    | 60        |
| 5.5      | Операційна модель <code>opr_f_seed</code> і межі квантового впливу . . . . .                  | 60        |
| 5.6      | Формальний аналіз і межі доведення . . . . .                                                  | 60        |
| 5.7      | Реалізація, простежуваність специфікації та вимірювання швидкодії . . . . .                   | 60        |
|          | Висновки до розділу 5 . . . . .                                                               | 61        |
| <b>6</b> | <b>Метод гібридного постквантового наскрізного шифрування</b>                                 | <b>62</b> |
| 6.1      | Постановка та гібридний криптографічний корінь . . . . .                                      | 62        |
| 6.2      | Класична автентифікація сторін . . . . .                                                      | 62        |
| 6.3      | Подвійний «храповик» з KEM-підсиленням кроком . . . . .                                       | 62        |
| 6.4      | Захист метаданих . . . . .                                                                    | 62        |
| 6.5      | Межі: повторне відтворення, відкот стану та пропущені ключі . . . . .                         | 62        |
| 6.6      | Формальні докази та узгодження тверджень . . . . .                                            | 62        |
| 6.7      | Груповий протокол в окреслених межах . . . . .                                                | 63        |
|          | Висновки до розділу 6 . . . . .                                                               | 63        |
| <b>7</b> | <b>Метод серверно-сліпого каналу нагляду</b>                                                  | <b>64</b> |
| 7.1      | Постановка задачі: приватний контрольований перегляд . . . . .                                | 65        |
| 7.2      | Згода, контрольована пристроєм дитини . . . . .                                               | 65        |
| 7.3      | Активний зв'язок між дитиною та опікуном . . . . .                                            | 65        |
| 7.4      | Виділення парного ключа для кожного пристрою . . . . .                                        | 65        |
| 7.5      | Маршрутизація непрозорого вмісту та роль сервера . . . . .                                    | 65        |
| 7.6      | Життєвий цикл підтвердження, відкликання та очищення . . . . .                                | 65        |
| 7.7      | Межі: повторне відтворення, час життя, відмова в обслуговуванні та межа приватності . . . . . | 65        |
| 7.8      | Наскрізний сценарій та відтворюваний доказ . . . . .                                          | 65        |
|          | Висновки до розділу 7 . . . . .                                                               | 66        |
| <b>8</b> | <b>Інформаційна технологія AURA/Ecliptix та експериментальна перевірка</b>                    | <b>67</b> |
| 8.1      | Архітектура реалізації . . . . .                                                              | 68        |
| 8.2      | Інтерфейси міжмовної взаємодії (FFI) . . . . .                                                | 68        |
| 8.3      | Інтеграція каналу нагляду та межа приватності пошуку . . . . .                                | 68        |
| 8.4      | Керування наборами даних . . . . .                                                            | 68        |

|     |                                                                              |           |
|-----|------------------------------------------------------------------------------|-----------|
| 8.5 | Оцінювання з контрольованим допуском до випуску та приватний аудит . . . . . | 68        |
| 8.6 | Експериментальна перевірка . . . . .                                         | 68        |
| 8.7 | Реєстр відтворюваних матеріалів та відтворюваність . . . . .                 | 68        |
| 8.8 | Обмеження та межі застосування . . . . .                                     | 68        |
|     | Висновки до розділу 8 . . . . .                                              | 69        |
|     | <b>Висновки</b>                                                              | <b>70</b> |
|     | <b>Додатки</b>                                                               | <b>74</b> |
|     | Додаток А. Реєстр відтворюваних матеріалів і перевірок . . . . .             | 74        |
|     | Додаток Б. Формальні моделі та фрагменти специфікацій . . . . .              | 74        |
|     | Додаток В. Додаткові таблиці вимірювань швидкодії . . . . .                  | 74        |
|     | Додаток Г. Акти впровадження та копії публікацій . . . . .                   | 74        |

# Перелік умовних позначень, символів і скорочень

| Скорочення | Розшифрування                                                   |
|------------|-----------------------------------------------------------------|
| AURA       | середовище виконання політик захисту контекстної приватності    |
| E2EE       | наскрізне шифрування                                            |
| PAKE       | протокол парольно-автентифікованого обміну ключами              |
| aPAKE      | асиметричний протокол парольно-автентифікованого обміну ключами |
| OPAQUE     | асиметричний PAKE-протокол на основі OPRF                       |
| OPRF       | сліпа псевдовипадкова функція                                   |
| PQ         | постквантовий                                                   |
| KEM        | механізм інкапсуляції ключа                                     |
| ML-KEM-768 | постквантовий KEM (FIPS 203), рівень безпеки 3                  |
| X25519     | протокол Діффі–Геллмана на кривій Curve25519                    |
| Ed25519    | схема цифрового підпису EdDSA на Curve25519                     |
| Argon2id   | функція хешування паролів із підсиленням пам'яті                |
| HKDF       | функція виведення ключів на основі HMAC                         |
| HMAC       | код автентифікації повідомлень на основі гешу                   |
| AEAD       | автентифіковане шифрування з асоційованими даними               |
| MRAE       | автентифіковане шифрування, стійке до помилкового використання  |
| DH         | протокол Діффі–Геллмана                                         |



| Скорочення                                   | Розшифрування                                                  |
|----------------------------------------------|----------------------------------------------------------------|
| Double Ratchet                               | протокол подвійного «храповика» Signal                         |
| X3DH                                         | / протоколи початкового узгодження ключів Signal               |
| PQXDH                                        | (класичний / постквантовий)                                    |
| MLS                                          | протокол захисту групового обміну повідомленнями (RFC 9420)    |
| канал нагляду                                | серверно-сліпий канал передавання захисних сигналів            |
| пристрій опікуна                             | кінцевий пристрій опікуна у сценарії контрольованого перегляду |
| ACK                                          | підтвердження доставки/встановлення                            |
| TTL                                          | час життя запису                                               |
| FFI                                          | інтерфейс міжмовної взаємодії                                  |
| ДСТУ                                         | національний стандарт України                                  |
| PASS / FAIL / INSUFFICIENT_SUPPORT / BLOCKED | статуси оцінювання якості з порогоми допуску                   |

# Вступ

## Актуальність теми

Сучасні захищені системи обміну повідомленнями з наскрізним шифруванням створюють принципову суперечність між приватністю комунікації та потребою захищати особу, насамперед дитину або іншу вразливу особу, від ризикових інформаційних впливів. *[Розкрити актуальність прозою на основі Розділу 1.]*

## Зв'язок роботи з науковими програмами, планами, темами

*[Зазначити НДР, держбюджетні/госпдоговірні теми, номери державної реєстрації у межах яких виконано роботу, та роль здобувача в них.]*

## Мета і завдання дослідження

**Метою роботи** є розроблення методології, методів та інформаційної технології захисту контекстної приватності особи у захищених цифрових комунікаційних середовищах, що забезпечують оцінювання інформаційного ризику та прийняття захисних рішень без розкриття відкритого тексту повідомлень серверу, спираючись на постквантово-посилену автентифікацію, гібридне наскрізне шифрування та серверно-сліпий канал нагляду.

Для досягнення мети поставлено такі **завдання**:

1. проаналізувати стан проблеми захисту контекстної приватності в захищених системах обміну повідомленнями, обмеження серверного контролю за

- наскрізного шифрування та недостатність позаконтекстної класифікації повідомлень, виявити наукову прогалину (розділ 1);
2. розробити концепцію інформаційної технології на основі середовища виконання політик AURA, узгоджену модель загроз та явні межі тверджень для всіх рівнів захисту (розділ 2);
  3. розробити метод контекстної оцінки інформаційного ризику, що враховує контакт, історію розмови, часову динаміку, повторюваність та латентні стани маніпуляції (розділ 3);
  4. розробити метод перетворення структурованого сигналу ризику в захисну дію з урахуванням політик, опрацюванням невизначеності та приватним аудитом (розділ 4);
  5. удосконалити криптографічну основу середовища виконання політик: метод постквантово-посиленої OPAQUE-автентифікації (розділ 5) та метод гібридного постквантового наскрізного шифрування (розділ 6);
  6. розробити метод серверно-сліпого каналу нагляду для передавання захисних сигналів пристрою опікуна без розкриття відкритого тексту серверу (розділ 7);
  7. реалізувати інформаційну технологію AURA/Ecliptix та виконати її експериментальну перевірку й оцінювання з порогами допуску, з визначенням обмежень і меж застосування (розділ 8).

## **Об'єкт і предмет дослідження**

**Об'єкт дослідження** – процеси інформаційного впливу, автентифікації, захищеного обміну повідомленнями та контекстної безпеки в цифрових комунікаційних середовищах.

**Предмет дослідження** – моделі, методи та програмні механізми захисту контекстної приватності особи, що охоплюють оцінювання ризику інформаційного впливу, приватне опрацювання захисних рішень, постквантово-посилену автентифікацію, гібридне наскрізне шифрування і серверно-сліпий канал нагляду.

## Методи дослідження

У роботі використано: методи системного аналізу та моделювання загроз (розділи 1–2); методи теорії інформаційної безпеки та криптографічного аналізу, зокрема формальну верифікацію протоколів засобами Tamarin та ProVerif (розділи 5–6); методи контекстного аналізу даних і прийняття рішень за умов невизначеності (розділи 3–4); методи інженерії програмного забезпечення, тестування та відтворювання експериментальної перевірки з порогами допуску (розділ 8).

## Наукова новизна одержаних результатів

1. **вперше запропоновано** архітектуру захисту контекстної приватності особи на основі середовища виконання політик AURA, у якій оцінювання ризику, захисні рішення з урахуванням політик, постквантово-посилена автентифікація, гібридне наскрізне шифрування та серверно-сліпий канал нагляду розглядаються як взаємопов'язані рівні однієї інформаційної технології, що, *на відміну від наявних підходів*, не потребує перенесення відкритого тексту повідомлень на сервер (розділ 2);
2. **вперше розроблено** метод контекстної оцінки інформаційного ризику в захищеному комунікаційному середовищі, у якому повідомлення розглядається як подія в контексті контакту, історії розмови, часової динаміки, повторюваності впливу та латентних станів маніпуляції, *що дозволяє* перейти від класифікації окремого повідомлення до структурованого сигналу ризику (розділ 3);
3. **удосконалено** метод прийняття рішень контекстної безпеки шляхом переходу від мітки ризику до простору захисних дій з урахуванням політик (дозвіл, попередження, ескалація, карантин, блокування, контрольований перегляд) з опрацюванням невизначеності та профілю захисту особи (розділ 4);
4. **удосконалено** метод постквантово-посиленої парольної автентифікації на основі OPAQUE шляхом гібридного DH/KEM-узгодження сесії та явного операційного розмежування секрету `opr_f_seed`, *що дозволяє* зберегти захист від перебору словника поза взаємодією із сервером за компрометації бази даних у межах визначеної моделі (розділ 5);

5. **удосконалено** метод гібридного постквантового наскрізного шифрування шляхом КЕМ-підсилення кроку «храповика», ротації ключів метаданих та чіткого розмежування меж формального доведення, тестування й реалізаційної перевірки (розділ 6);
6. **вперше запропоновано** метод серверно-сліпого каналу нагляду, у якому згода, контрольована пристроєм дитини, активний зв'язок між дитиною та опікуном і виділення парного ключа для кожного пристрою дають змогу передавати захисні сигнали пристрою опікуна без розкриття їхнього відкритого тексту серверу (розділ 7);
7. **удосконалено** модель меж компрометації середовища виконання політик захисту контекстної приватності та методологію його приватного аудиту й оцінювання з порогамі допуску шляхом розмежування сценаріїв компрометації і поєднання кураторських та синтетичних корпусів зі статусами PASS, FAIL, INSUFFICIENT\_SUPPORT, BLOCKED (розділи 2, 8);
8. **розроблено** інформаційну технологію AURA/Ecliptix, яка реалізує запропоновані методи у вигляді програмного комплексу на основі Rust, iOS-застосунку та серверної частини з відтворюваною перевіркою й приватним аудитом (розділ 8).

## Практичне значення одержаних результатів

*[Розкрити: придатність методів і технологій для захищених систем обміну повідомленнями, зокрема сценаріїв захисту дітей; впровадження в AURA/Ecliptix; відтворювані матеріали перевірки, тести, звіти допуску до випуску; акти впровадження за наявності.]*

## Особистий внесок здобувача

*[Усі основні результати отримано здобувачем особисто. Для робіт у співавторстві – конкретизувати внесок здобувача по кожній публікації.]*

## **Апробація результатів дисертації**

*[Перелічити конференції, семінари, доповіді, де оприлюднено результати.]*

## **Публікації**

*[Кількість і перелік публікацій за темою – див. розгорнутий список у анотації.*

*Зазначити статті у фахових виданнях та виданнях, проіндексованих у Scopus/Web of Science, і праці апробаційного характеру.]*

## **Структура та обсяг дисертації**

Дисертація складається зі вступу, восьми розділів, висновків, списку використаних джерел та додатків. *[Уточнити загальний обсяг, кількість рисунків, таблиць, найменувань у списку джерел після завершення тексту.]*



## **Розділ 1**

# **Аналіз стану проблеми захисту контекстної приватності у захищених системах обміну повідомленнями**

- 1.1. Приватна цифрова комунікація та модель наскрізного шифрування**
- 1.2. Ризикові інформаційні впливи в приватних каналах**
- 1.3. Дилема модерації за наскрізного шифрування**
- 1.4. Недостатність позаконтекстної класифікації повідомлень**
- 1.5. Парольна автентифікація та augmented PAKE**
- 1.6. Постквантовий перехід в автентифікації та обміні повідомленнями**

- 1.7. Системи батьківського контролю та нагляду**



повідомленнями розглядають як відокремлені рівні. *[Розкрити прогалину прозою й сформулювати постановку задачі.]*

## **Висновки до розділу 1**

*[Сформулювати висновки до розділу 1 після написання основного тексту.]*

## Розділ 2

# Концепція інформаційної технології на основі середовища виконання політик AURA

У розділі розроблено концепцію інформаційної технології захисту контекстної приватності особи на основі середовища виконання політик AURA. На відміну від розділу 1, де обґрунтовано наукову прогалину та показано роз'єднаність підходів до автентифікації, наскрізного шифрування, постквантового підсилення і контекстної безпеки, у цьому розділі ці напрями подано як взаємопов'язані рівні однієї технології. Центральним є не окремий програмний виріб і не окремий криптографічний протокол, а середовище виконання політик, у якому відкритий текст повідомлення опрацьовується локально на кінцевому пристрої, перетворюється на структурований сигнал ризику і лише після цього відображається у захисну дію.

Таке трактування потрібне з двох причин. По-перше, інференційні загрози цифрового середовища не зводяться до наявності заборонених слів або одноразового виявлення небажаного повідомлення. Вони виникають як послідовність дій, натяків, повторень, зміни тональності, перенесення довіри, ескалації тиску або побудови залежності між учасниками взаємодії. По-друге, захищене цифрове комунікаційне середовище не може відповідати на ці загрози шляхом повернення відкритого тексту на сервер, оскільки це суперечить самій ідеї наскрізного

шифрування і створює інфраструктуру масового спостереження [1, 2, 3]. Отже, концепція AURA має поєднати дві вимоги, які часто розглядають окремо: збереження приватності змісту повідомлень і здатність приймати контекстні захисні рішення.

Розділ визначає головну тезу роботи, формальне подання середовища AURA, архітектурні інваріанти інформаційної технології, рівні моделювання системи, потік даних від повідомлення до захисного рішення, уніфіковану модель загроз та межі тверджень. Ці положення є спільною рамкою для методів, розгорнутих у розділах 3–8.

## **2.1. Середовище AURA як центральний рівень прийняття рішень**

Головна теза роботи полягає в тому, що захист контекстної приватності особи має бути *контекстним, таким, що підтримує стан взаємодії, та орієнтованим на середовище виконання політик*. Криптографія у цій тезі не замінює контекстний захист, а створює умови, за яких він може виконуватися без серверного доступу до відкритого тексту повідомлень. Інакше кажучи, криптографічні методи визначають межу, за яку сервер не повинен переходити, а середовище AURA визначає, що саме має відбутися всередині цієї межі після отримання повідомлення кінцевим пристроєм.

Під *контекстною приватністю особи* у роботі розуміється властивість захищеного цифрового середовища обмежувати небажане розкриття, виведення або використання відомостей про особу, її стан, наміри, соціальні зв'язки, вразливості та історію взаємодії, коли такі відомості можуть бути отримані не лише з окремого повідомлення, а й з послідовності повідомлень, поведінкової динаміки та службових ознак. Це визначення навмисно ширше за конфіденційність відкритого тексту. Наскрізне шифрування захищає зміст від сервера та стороннього спостерігача, але саме по собі не визначає, як реагувати на ризиковий інформаційний вплив, що вже потрапив на пристрій адресата.

Середовище AURA у цій роботі подається як рівень прийняття рішень, що має три обов'язкові функції:

1. формує подію повідомлення в контексті, а не розглядає повідомлення

як ізольований текстовий об'єкт.

2. обчислює структурований сигнал інформаційного ризику з урахуванням історії взаємодії, контакту, часової динаміки, предметної області та невизначеності;
3. перетворює цей сигнал у захисну дію відповідно до політик, меж втручання та профілю захисту особи.

Формально подію повідомлення можна подати як

$$e_i = \langle m_i, u_s, u_r, c_i, t_i, h_i, q_i \rangle, \quad (2.1)$$

де  $m_i$  – відкритий текст повідомлення після локального розшифрування на кінцевому пристрої,  $u_s$  і  $u_r$  – учасники взаємодії,  $c_i$  – стан контакту,  $t_i$  – часова ознака,  $h_i$  – локально доступна історія розмови,  $q_i$  – режим предметної області та додаткові ознаки, дозволені політикою. Тоді середовище AURA реалізує два послідовні відображення:

$$r_i = \text{Risk}(e_i, H_i, \Pi_i, \Theta), \quad (2.2)$$

$$a_i = \text{Act}(r_i, H_i, \Pi_i, \Omega), \quad (2.3)$$

де  $r_i$  – структурований сигнал ризику,  $a_i$  – захисна дія,  $H_i$  – локальний стан взаємодії,  $\Pi_i$  – набір політик,  $\Theta$  – параметри методу оцінювання ризику,  $\Omega$  – параметри методу прийняття рішень.

Рівняння (2.1)–(2.3) не є твердженням про конкретний алгоритм машинного навчання або конкретну реалізацію. Вони фіксують архітектурну сутність запропонованої технології: відкритий текст повідомлення потрапляє до середовища виконання політик лише на кінцевому пристрої, після чого локально породжується сигнал ризику і локально або через непрозорий для сервера канал породжується захисна дія. Метод формування  $r_i$  розроблено в розділі 3, метод формування  $a_i$  – у розділі 4.

Принциповою є відмова від двох спрощень. Перше спрощення полягає у припущенні, що захист особи можна звести до класифікації одного повідомлення. Таке припущення не враховує повторюваності, наростання тиску, зміни асиметрії влади між учасниками, прихованого переведення розмови в інший канал або накопичення малих сигналів ризику. Друге спрощення полягає у припущенні,

що серверний доступ до відкритого тексту є неминучою платою за безпеку. У запропонованій концепції захисне рішення приймається там, де відкритий текст уже легітимно присутній, тобто на кінцевому пристрої особи.

Психологічні поняття, зокрема маніпуляція, примус, грумінг або вразливий стан, у межах цієї дисертації не трактуються як клінічні діагнози. Вони використовуються як формалізовані сигнали для оцінювання інформаційного ризику та прийняття захисних рішень. Це важлива межа твердження: робота розробляє інформаційну технологію і методи контекстного захисту, а не медичну або психологічну діагностичну систему.

## 2.2. Архітектурні інваріанти інформаційної технології

Концепція AURA спирається на набір інваріантів, які мають виконуватися незалежно від конкретної реалізації, набору політик або предметної області застосування. Інваріантом тут названо властивість архітектури, порушення якої змінює саму природу запропонованого підходу і повертає систему до одного з уже відомих проблемних класів: серверного контролю відкритого тексту, позаконтекстної класифікації, непрозорого втручання або невідтворюваного оцінювання.

Табл. 2.1: Інваріанти архітектури AURA

| Інваріант                     | Зміст                                                                                                          | Наслідок<br>для<br>роботи     |
|-------------------------------|----------------------------------------------------------------------------------------------------------------|-------------------------------|
| Локальність відкритого тексту | відкритий текст повідомлення, історія розмови та проміжні стани оцінювання ризику не передаються серверу       | межа приватності розділів 3–4 |
| Підтримання стану             | рішення спирається не лише на поточне повідомлення, а й на стан контакту, історію взаємодії та часову динаміку | новизна методу розділу 3      |

| <b>Інваріант</b>                | <b>Зміст</b>                                                                                                      | <b>Наслідок<br/>для<br/>роботи</b> |
|---------------------------------|-------------------------------------------------------------------------------------------------------------------|------------------------------------|
| Розділення сигналу і дії        | оцінка ризику від політики тому однаковий сигнал може породжувати різні дії для різних профілів захисту           | метод розділу 4                    |
| Криптографічний захисний контур | автентифікація, узгодження сесії, захист повідомлень і канал нагляду не відкривають зміст серверу                 | розділи 5–7                        |
| Непрозорість для сервера        | сервер виконує маршрутизацію, зберігання й доставку, але не отримує відкритого тексту захисних сигналів           | розділ 7                           |
| Відтворювана перевірка          | якість і межі технології мають перевірятися через визначені корпуси, пороги допуску та записи приватної перевірки | розділ 8                           |
| Межова доказовість              | формальні, експериментальні та реалізаційні твердження не підміняють одне одного                                  | розділи 2, 5–8                     |

Перший інваріант є найважливішим для теми дисертації. Якщо відкритий текст або повний контекст розмови передається серверу, система може стати корисною як засіб централізованого контролю, але втрачає властивість захисту контекстної приватності. Другий інваріант відрізняє запропонований підхід від класифікації окремого повідомлення. Третій інваріант створює основу для розділу 4: ризик і дія не є одним і тим самим, оскільки дія залежить від віку, ролі, згоди, режиму предметної області, допустимого втручання і рівня невизначеності. Четвертий і п'ятий інваріанти формують криптографічну та організаційну межу, без якої локальність відкритого тексту була б декларативною. Шостий і сьомий інваріанти захищають наукову доброчесність результату:

якість AURA не можна стверджувати без відтворюваної перевірки, а формальна верифікація протоколів не доводить психологічну правильність захисних рішень.

## 2.3. Методологічні засади побудови інформаційної технології

Концепція AURA не може бути обґрунтована лише переліком програмних складових. Для докторської роботи важливо показати, на яких методологічних засадах побудовано інформаційну технологію і чому ці засади не є випадковим набором інженерних рішень. У цій роботі вихідною є така постановка: цифрове середовище має захищати особу від ризикового інформаційного впливу, але не повинно перетворювати захист на новий канал розкриття приватного змісту. Отже, система має одночасно підтримувати контекстність, приватність, підзвітність, відтворюваність і межу доказовість.

Першою засадою є *приватність за будовою*. Вона означає, що відкритий текст повідомлення не переноситься до сервера для оцінювання ризику. Система не додає серверне читання як приховану умову безпеки, а розміщує оцінювання в тій області, де відкритий текст уже присутній законно і технічно обґрунтовано. Ця засада відрізняє запропоновану технологію від централізованого контролю вмісту, де безпека досягається через послаблення конфіденційності.

Другою засадою є *контекстність замість одноразової класифікації*. У межах цієї засади повідомлення не розглядається як самодостатній об'єкт. Одне й те саме повідомлення може мати різний ризиковий зміст залежно від історії взаємодії, віку та ролі учасників, часової динаміки, попередніх сигналів і предметного режиму. Тому основним об'єктом опрацювання є подія в контексті, а не окрема фраза.

Третьою засадою є *розділення оцінювання і дій*. Структурований сигнал ризику не повинен автоматично означати блокування, ескалацію або передавання опікуну. Оцінювання ризику належить до розділу 3, а виконання політики належить до розділу 4. Це розділення потрібне для наукової коректності, оскільки помилково ототожнювати факт ризику з конкретним способом втручання. Воно також потрібне для практичної гнучкості, оскільки однаковий сигнал може вимагати різних дій у різних умовах.

Четвертою засадою є *мінімізація даних*. Локальна система не повинна

накопичувати більше відкритого тексту, ніж потрібно для виконання методу. Пам'ять взаємодії має будуватися як контрольоване представлення контексту, а не як необмежене сховище розмов. Така засада створює внутрішню межу навіть усередині кінцевого пристрою: якщо певна ознака не потрібна для оцінювання ризику або не дозволена політикою, вона не повинна входити до стану AURA.

П'ятою засадою є *підзвітність без розкриття*. Система має створювати умови для перевірки якості та пояснення захисного рішення, але така перевірка не повинна перетворюватися на масове розкриття приватних розмов. Тому в роботі розрізняються повний відкритий текст, локальні представлення, захисні сигнали, службові дані та відтворені матеріали перевірки.

Шостою засадою є *межова доказовість*. Кожне твердження має відповідати своєму виду доказу. Криптографічна властивість не доводить якість контекстного рішення. Експериментальна якість на корпусі не доводить секретність ключа. Програмна реалізація не є повним математичним доказом системної безпеки. Саме тому в розділі 2.16 окремо визначено межі тверджень.

Табл. 2.2: Методологічні засади побудови технології AURA

| Засада                    | Зміст                                                                         | Роль у роботі |
|---------------------------|-------------------------------------------------------------------------------|---------------|
| Приватність будовою       | за відкритий текст не передається серверу для оцінювання ризику               | розділи 2–4   |
| Контекстність             | повідомлення оцінюється як подія в історії взаємодії                          | розділ 3      |
| Розділення оцінювання дії | і сигнал ризику відокремлено від політики реагування                          | розділи 3–4   |
| Мінімізація даних         | локальний стан містить лише потрібні й дозволені політикою представлення      | розділи 3, 8  |
| Підзвітність розкриття    | без перевірка якості не повинна вимагати масового відкриття приватного змісту | розділи 7–8   |



| Засада             | Зміст                                                                   | Роль у роботі  |
|--------------------|-------------------------------------------------------------------------|----------------|
| Межова доказовість | формальні, експериментальні та реалізаційні твердження мають різні межі | розділи 2, 5–8 |

Ці засади задають критерій відбору всіх подальших технічних рішень. Якщо рішення вимагає серверного доступу до відкритого тексту, воно суперечить приватності за будовою. Якщо рішення не враховує історію взаємодії, воно не реалізує контекстність. Якщо рішення одразу замінює сигнал ризику на дію, воно порушує розділення оцінювання і політики. Якщо рішення не має відтворюваної перевірки, воно не досягає рівня доказовості, потрібного для докторської роботи.

## 2.4. Понятійна модель контекстної приватності

Подальше розгортання інформаційної технології потребує чіткого понятійного апарату. У межах цієї дисертації приватність не ототожнюється лише з таємницею повідомлення, а захист не ототожнюється лише з блокуванням шкідливого висловлювання. Центральним об'єктом є особа в цифровому середовищі, щодо якої з повідомлень, службових ознак і послідовності взаємодій можуть виводитися відомості, що підвищують її вразливість або створюють підстави для небажаного впливу.

Особу в контексті цієї роботи доцільно розглядати як носія не одного ідентифікатора, а множини взаємопов'язаних ознак:

$$P = \langle I, S, V, G, N, L \rangle, \quad (2.4)$$

де  $I$  – ідентифікаційні ознаки,  $S$  – поточний стан взаємодії,  $V$  – можливі вразливості,  $G$  – соціальні зв'язки,  $N$  – норми та обмеження предметної області,  $L$  – локально доступна історія. Це подання не означає, що система має збирати всі такі ознаки. Навпаки, воно показує, чому приватність особи не можна звести до приховування одного текстового поля. Ризик виникає саме тоді, коли часткові ознаки починають працювати разом.

Інференційна загроза в цій роботі трактується як можливість виведення нових або чутливих відомостей про особу з поєднання прямих повідомлень, службових ознак, часової динаміки, повторюваності тем і поведінки учасників. У загальному вигляді таке виведення можна подати як

$$\hat{P}_i = \text{Infer}(\mathcal{O}_i, H_i, \mathcal{M}_i), \quad (2.5)$$

де  $\hat{P}_i$  – оцінене або виведене подання відомостей про особу,  $\mathcal{O}_i$  – спостережувані ознаки поточної взаємодії,  $H_i$  – локальний стан,  $\mathcal{M}_i$  – модель виведення, явна або неявна. Для запропонованої технології важливо не те, що всі такі виведення точно відомі системі, а те, що сама архітектура визнає їх джерелом ризику і не зводить захист до пошуку забороненого слова.

Звідси випливає важлива методологічна межа. AURA не має встановлювати істину про внутрішній стан людини. Вона має виявляти інформаційні умови, за яких взаємодія стає ризиковою для приватності, автономії або безпеки особи. Тому сигнал ризику  $r_i$  є не діагнозом і не моральною оцінкою учасника, а обчислюваним поданням ознак, невизначеності та можливого способу реагування.

Табл. 2.3: Базові поняття концепції захисту контекстної приватності

| Поняття            | Зміст у межах роботи                                                                                         | Призначення       |
|--------------------|--------------------------------------------------------------------------------------------------------------|-------------------|
| Особа              | учасник цифрової взаємодії, щодо якого захищається приватність, автономія та безпека інформаційної поведінки | об’єкт захисту    |
| Подія повідомлення | повідомлення разом з учасниками, часом, контакту, історією предметним режимом                                | з одиниця аналізу |
| Локальний стан     | мінімізоване представлення попередньої взаємодії кінцевому пристрої                                          | носій контексту   |

| Поняття             | Зміст у межах роботи                                                                             | Призначення                |
|---------------------|--------------------------------------------------------------------------------------------------|----------------------------|
| Інформаційний ризик | структуроване подання можливості небажаного впливу, розкриття або виведення відомостей про особу | результат оцінювання       |
| Політика захисту    | правила переходу від сигналу ризику до допустимої дії                                            | межа втручання             |
| Захисна дія         | попередження, обмеження, карантин, блокування, ескалація або контрольований перегляд             | результат рішення          |
| Захисний контур     | сукупність криптографічних і системних меж, що не дають серверу доступу до відкритого тексту     | технічна умова приватності |
| Приватна перевірка  | відтворюваний контроль якості без масового розкриття приватного змісту                           | наукова підзвітність       |

Така понятійна модель потрібна для подальших розділів з трьох причин. По-перше, вона відокремлює об'єкт захисту від програмного засобу. Захищається не застосунок і не сервер, а особа в умовах цифрової взаємодії. По-друге, вона відокремлює повідомлення від події. Подія містить контекст, без якого ризик може бути невидимим або неправильно витлумаченим. По-третє, вона відокремлює ризик від дії. Ризик є інформаційним сигналом, а дія є рішенням політики і технічного виконання в межах допустимого втручання.

На цьому рівні AURA постає як середовище, що виконує перехід від події до ризику і від ризику до дії, не порушуючи межу відкритого тексту. Саме тому в дисертації AURA не описується як окрема програма для обміну повідомленнями. Вона є узагальненою технологічною ланкою, яку можна розміщувати в захищених цифрових комунікаційних середовищах за умови виконання визначених інваріантів.

## 2.5. Загальна архітектура AURA/Ecliptix

Запропонована інформаційна технологія структурується як п'ять взаємопов'язаних рівнів. У цій структурі криптографічні рівні не є самодостатньою метою, а утворюють захисний контур для приватної роботи середовища виконання політик.

1. **Рівень автентифікації.** Постквантово-посилена парольна автентифікація на основі OPAQUE [4, 5], за якої пароль не передається серверу, а компрометація серверного запису не повинна давати негайної переваги перебору поза взаємодією із сервером у визначеній моделі (розділ 5).
2. **Рівень захищеного обміну.** Гібридне постквантово-посилене наскрізне шифрування, що розвиває модель Double Ratchet [6] та її постквантове підсилення [7] і узгоджується зі стандартизованим груповим шифруванням MLS [8] (розділ 6).
3. **Рівень контекстної безпеки.** Середовище AURA, що локально оцінює інформаційний ризик, підтримує стан взаємодії та приймає захисні рішення з урахуванням політик (розділи 3–4).
4. **Рівень нагляду, непрозорий для сервера.** Канал передавання захисних сигналів пристрою опікуна без розкриття їхнього відкритого тексту серверу. Концептуально він спирається на ідею підзвітного каналу, що зберігає конфіденційність [9], але в роботі розгортається як окремий метод для сценаріїв контекстного захисту (розділ 7).
5. **Реалізаційний рівень.** Програмна інформаційна технологія AURA/Ecliptix, що охоплює серверні компоненти на Rust, iOS-застосунок, засоби міжмовної взаємодії, відтворювані перевірки і приватну перевірку (розділ 8).

Ці рівні утворюють не послідовність незалежних удосконалень, а єдину архітектуру. Автентифікація створює облікову основу довіри. Наскрізне шифрування захищає повідомлення і довготривалу конфіденційність за постквантового переходу. Середовище AURA приймає локальні контекстні рішення. Канал нагляду передає окремі захисні сигнали лише у визначених політикою випадках і не відкриває зміст серверу. Реалізаційний рівень зв'язує ці методи в інформаційну технологію, яку можна перевіряти, повторювати й оцінювати.

Архітектурна новизна полягає не в тому, що кожен із рівнів окремо є невідомим у науковій літературі. Науковий результат полягає у способі їх поєднання навколо середовища виконання політик контекстної приватності. Саме це поєднання дозволяє не протиставляти приватність і захисне втручання. Сервер не отримує відкритого тексту, але кінцевий пристрій отримує достатній локальний контекст для оцінювання ризику і виконання політики.

## 2.6. Системні ролі та області відповідальності

Для цілісної концепції недостатньо описати рівні технології. Потрібно також визначити системні ролі, оскільки саме вони задають, хто є джерелом повідомлення, хто приймає ризик, хто виконує службові функції, хто може здійснювати контрольований перегляд і хто відповідає за політику захисту. Невизначеність ролей призводить до двох помилок: або сервер отримує надмірну владу над приватним змістом, або кінцевий пристрій отримує захисні функції без меж відповідальності.

У роботі розрізняються такі ролі.

1. **Особа, що захищається.** Це учасник взаємодії, для якого система має обмежувати ризиковий інформаційний вплив. У важливому прикладному сценарії такою особою є дитина або інша вразлива особа, але сама модель не зводиться лише до дитячого застосування.
2. **Контакт.** Це інший учасник розмови, від якого надходять повідомлення або з яким відбувається взаємодія. Контакт не оголошується наперед шкідливим. Ризик формується через події, історію та контекст, а не через просте віднесення контакту до небезпечного класу.
3. **Кінцевий пристрій особи.** Це область, у якій відкритий текст присутній після розшифрування і в якій виконується середовище AURA. Саме цей пристрій формує подію повідомлення, оновлює локальний стан і породжує сигнал ризику.
4. **Сервер.** Сервер виконує функції реєстрації, маршрутизації, доставки та службового обслуговування, але не повинен отримувати відкритий текст повідомлень або відкритий зміст захисних сигналів.

5. **Опікун або уповноважений захисний учасник.** Ця роль виникає лише в сценаріях контрольованого перегляду, дозволених політикою системи. Вона не означає постійного доступу до приватного змісту і не замінює локальне рішення AURA.
6. **Укладач політики.** Це суб'єкт або сукупність правил, що визначають допустимі дії системи, пороги втручання, умови нагляду, терміни зберігання локальних представлень і межі приватної перевірки.
7. **Перевірник якості.** Це роль, пов'язана з відтворюваною перевіркою методів, корпусів, порогів допуску та реалізаційних властивостей. Вона не повинна мати автоматичного доступу до приватного змісту користувачів.

Таблиця 2.4 узагальнює ці ролі з погляду доступу до даних і відповідальності. Вона також показує, що поняття «система» у роботі не ототожнюється із сервером. Навпаки, сервер є лише одним із елементів, а центр прийняття контекстних рішень розміщено на кінцевому пристрої.

Табл. 2.4: Системні ролі та області відповідальності

| Роль                  | Допустима область доступу                                       | Відповідальність                                                    |
|-----------------------|-----------------------------------------------------------------|---------------------------------------------------------------------|
| Особа, що захищається | власні повідомлення, локальні попередження, дозволені пояснення | отримання захисної дії без втрати приватності                       |
| Контакт               | власні повідомлення та звичайний перебіг взаємодії              | участь у розмові без доступу до локального стану AURA іншої сторони |
| Кінцевий пристрій     | відкритий текст після розшифрування, локальний стан, політики   | формування події, оцінювання ризику, виконання локальних дій        |

| <b>Роль</b>       | <b>Допустима область доступу</b>                            | <b>Відповідальність</b>                                   |
|-------------------|-------------------------------------------------------------|-----------------------------------------------------------|
| Сервер            | шифротекст, службові дані, непрозорі канали нагляду         | маршрутизація, зберігання, доставка, обмеження зловживань |
| Опікун            | лише дозволені політикою сигнали або контрольований зміст   | допомога у визначених сценаріях без серверного розкриття  |
| Укладач політики  | правила, пороги, межі втручання, умови зберігання           | формування допустимої області дій системи                 |
| Перевірник якості | знеособлені або спеціально підготовлені матеріали перевірки | відтворення оцінювання та контроль меж тверджень          |

Таке розмежування ролей має принципове значення для захисту контекстної приватності. Якщо роль сервера розширити до аналізу відкритого тексту, технологія втрачає головну властивість. Якщо роль опікуна зробити необмеженою, контрольова перегляд перетворюється на постійний нагляд. Якщо роль укладача політики не відокремити від оцінювання ризику, система може почати видавати рішення політики або організаційні приписи за об'єктивну оцінку інформаційної загрози. Тому ролі задають не лише організаційну структуру, а й наукову межу моделі.

## 2.7. Довірені області та класи даних

Після визначення ролей потрібно зафіксувати, які області системи вважаються довіреними для певних класів даних. Це питання є центральним для захисту контекстної приватності. Якщо відкритий текст формально захищений під час передавання, але потім потрапляє до сервера для оцінювання ризику, архітектура втрачає свою приватнісну основу. Якщо ж усі рішення залишаються локальними

без можливості контрольованої допомоги, система може бути недостатньою для захисту дитини або іншої вразливої особи. Тому потрібне не абсолютне замикання, а точне розмежування областей довіри.

У роботі виділяються чотири основні області. Перша область – кінцевий пристрій особи, де відкритий текст з'являється після розшифрування і де виконується середовище AURA. Друга область – сервер, що бачить шифротекст і службові ознаки доставки, але не повинен бачити відкритий зміст повідомлень і відкриті захисні сигнали. Третя область – пристрій опікуна або уповноваженого захисного учасника, що може отримувати лише дозволені політикою захищені блоки. Четверта область – середовище перевірки якості, у якому мають використовуватися знеособлені, синтетичні або спеціально підготовлені матеріали.

Формально це можна подати як множину областей

$$\mathcal{Z} = \{Z_U, Z_S, Z_G, Z_V\}, \quad (2.6)$$

де  $Z_U$  – область кінцевого пристрою особи,  $Z_S$  – серверна область,  $Z_G$  – область контрольованого захисного учасника,  $Z_V$  – область відтворюваної перевірки. Для кожного класу даних визначається допустима область існування:

$$\text{Allow} : \mathcal{D} \rightarrow 2^{\mathcal{Z}}, \quad (2.7)$$

де  $\mathcal{D}$  – множина класів даних. Це відображення не є технічною деталлю. Воно є частиною методології, оскільки показує, коли реалізація відповідає концепції AURA, а коли порушує її.

Табл. 2.5: Класи даних і допустимі області їх існування

| Клас даних      | Зміст         |              | Допустимі області |   |
|-----------------|---------------|--------------|-------------------|---|
| Відкритий текст | зміст         | повідомлення | $Z_U$ ,           | у |
|                 | після         | локального   | дозволених        |   |
|                 | розшифрування |              | випадках          |   |
|                 |               |              | обмежено          |   |
|                 |               |              | $Z_G$             |   |



| Клас даних                | Зміст                                                                           | Допустимі області                            |
|---------------------------|---------------------------------------------------------------------------------|----------------------------------------------|
| Локальна історія          | мінімізоване подання<br>попередньої взаємодії та<br>стану контакту              | $Z_U$                                        |
| Проміжні<br>ознаки ризику | ознаки, з яких формується<br>структурований сигнал<br>ризик                     | $Z_U$                                        |
| Сигнал ризику             | результат оцінювання<br>з рівнем, класом,<br>впевненістю та<br>невизначеністю   | $Z_U$ , захищено<br>$Z_G$                    |
| Захисна дія               | рішення політики про<br>попередження, обмеження,<br>карантин або ескалацію      | $Z_U$ , за потреби<br>$Z_G$                  |
| Шифротекст                | зашифровані повідомлення<br>і захищені блоки каналу<br>нагляду                  | $Z_S$ , $Z_U$ , $Z_G$                        |
| Службові<br>ознаки        | час доставки, розміри,<br>черги, підтвердження та<br>технічні стани             | $Z_S$ , $Z_U$                                |
| Матеріал<br>перевірки     | знеособлені або спеціально<br>підготовлені записи для<br>повторюваного контролю | $Z_V$ , за<br>правилами<br>мінімізації $Z_U$ |

Це розмежування показує, що приватність у роботі не є загальною декларацією. Вона задається конкретною заборонаю на переміщення певних класів даних у певні області. Відкритий текст і локальна історія не повинні потрапляти до серверної області. Сигнал ризику може бути переданий опікуну лише як захищений блок і лише тоді, коли це дозволено політикою. Матеріали перевірки не повинні бути копією приватних розмов. Службові ознаки не приховуються повністю, але їхня наявність окремо враховується в межах тверджень.

Для докторської роботи така модель має особливе значення. Вона дозволяє формально пояснити, чому AURA не є серверною системою спостереження

і не є лише локальним фільтром. Це середовище виконання політик, у якому кожний клас даних має визначену область існування, а перехід між областями потребує криптографічного обґрунтування або обґрунтування з боку політики захисту. Надалі ця модель використовується для обґрунтування каналу нагляду, непрозорого для сервера, та для побудови реєстру відтворюваних матеріалів.

## 2.8. Рівні моделювання системи

Щоб уникнути змішування архітектури системи з окремими методами, у роботі використано багаторівневе моделювання. Розділ 2 фіксує систему в цілому, тобто її межі, ролі, інформаційні потоки, довірені та недовірені області, а також місце середовища AURA у загальній інформаційній технології. Розділ 3 розгортає архітектуру та моделі підсистеми контекстного оцінювання інформаційного ризику. Розділ 4 описує модель виконання політик, у якій структурований сигнал ризику перетворюється на захисну дію.

У такій логіці дисертація спирається на п'ять взаємопов'язаних рівнів моделювання. Вони не є п'ятьма незалежними описами однієї системи. Кожен рівень відповідає на окреме наукове питання: де проходить межа системи, що саме вважається подією, як зберігається локальний контекст, як із контексту формується ризик і як ризик переходить у дію.

**1. Системна модель.** Системна модель задає зовнішню рамку всієї інформаційної технології. Вона визначає склад учасників, межі між кінцевим пристроєм, сервером і пристроєм опікуна, класи даних, припущення довіри та допустимі напрями передавання інформації. У найбільш загальному вигляді систему можна подати як

$$S = \langle \mathcal{U}, \mathcal{D}, \mathcal{R}, \mathcal{B}, \mathcal{K}, \mathcal{P}, \mathcal{V} \rangle, \quad (2.8)$$

де  $\mathcal{U}$  – множина учасників взаємодії,  $\mathcal{D}$  – множина пристроїв,  $\mathcal{R}$  – ролі учасників,  $\mathcal{B}$  – межі довіри,  $\mathcal{K}$  – криптографічний контур,  $\mathcal{P}$  – політики захисту,  $\mathcal{V}$  – відтворювані механізми перевірки. Така модель потрібна не для деталізації кожного програмного компонента, а для фіксації принципу: відкритий текст, локальна історія та проміжні стани AURA належать до області кінцевого пристрою, тоді як сервер має виконувати лише обмежені службові функції.

Системна модель також розмежовує, які частини роботи належать до криптографічної безпеки, які – до контекстного оцінювання, які – до виконання

політик, а які – до експериментальної перевірки. Вона є точкою входу для всіх наступних моделей. Без неї окремі методи виглядали б як сукупність технічних рішень, а не як єдина інформаційна технологія захисту контекстної приватності.

**2. Модель події повідомлення.** Модель події повідомлення уточнює, що одиницею аналізу є не текстовий рядок, а подія в системі. Її базове подання вже задано рівнянням (2.1). До події входять відкритий текст після локального розшифрування, учасники взаємодії, стан контакту, часова ознака, локально доступна історія та предметний режим. Саме ця модель відокремлює запропонований підхід від класифікації окремого повідомлення.

На цьому рівні важливо не розширити набір ознак довільно, а показати, які ознаки допустимі в межах політики і не виводять систему за межу приватності. Наприклад, повідомлення може бути ризиковим не через окреме слово, а через те, що воно повторює попередній мотив, надходить у нетиповий час, змінює тональність контакту або продовжує вже виявлену послідовність тиску. Тому модель події повідомлення є мостом між системною архітектурою розділу 2 та докладною архітектурою підсистеми оцінювання ризику в розділі 3.

**3. Модель локального стану взаємодії.** Модель локального стану взаємодії описує, як система пам'ятає контекст без передавання відкритого тексту серверу. У концептуальному вигляді локальний стан можна подати як

$$H_i = \langle C_i, M_i, T_i, L_i, Q_i \rangle, \quad (2.9)$$

де  $C_i$  – стан контакту,  $M_i$  – пам'ять розмови,  $T_i$  – часові закономірності,  $L_i$  – латентні ознаки інформаційного впливу,  $Q_i$  – предметний режим. Це не означає, що система має зберігати повний відкритий текст усієї історії. Навпаки, модель стану повинна підтримувати мінімізацію: зберігаються лише ті локальні представлення, які потрібні для оцінювання ризику і дозволені політикою.

Цей рівень є ключовим для докторської новизни, оскільки саме він перетворює AURA з одноразового засобу класифікації на систему з пам'яттю взаємодії. Контактна пам'ять дає змогу враховувати довіру, повторні сигнали та зміну характеру зв'язку. Пам'ять розмови дає змогу бачити послідовність тем і повернення до ризикових мотивів. Часова частина стану відображає частоту, сплесковість і наростання тиску. Латентні ознаки описують не психологічний діагноз, а формалізовані стани системи, потрібні для обережного оцінювання ризику.

**4. Модель ризику.** Модель ризику встановлює, як подія повідомлення та локальний стан перетворюються на структурований сигнал  $r_i$ . У роботі важливо не звести цей сигнал до однієї числової оцінки. Для подальшого виконання політик потрібна структура, яка показує тип ризику, рівень, впевненість, джерела ознак, невизначеність і придатність сигналу до дії. У концептуальному вигляді такий сигнал можна подати як

$$r_i = \langle \rho_i, \kappa_i, \gamma_i, E_i, \Delta_i, \mu_i \rangle, \quad (2.10)$$

де  $\rho_i$  – рівень ризику,  $\kappa_i$  – клас ризику,  $\gamma_i$  – ступінь впевненості,  $E_i$  – джерела ознак,  $\Delta_i$  – невизначеність,  $\mu_i$  – ознака придатності до подальшого рішення.

На цьому рівні фіксується межа між оцінюванням і дією. Розділ 3 має відповідати на питання, як отримати  $r_i$ . Він не повинен остаточно вирішувати, чи треба блокувати повідомлення, попереджати особу або передавати сигнал опікуну. Це принципово інша задача, яку розв’язує розділ 4. Таке розділення захищає метод від надмірного твердження, ніби ризик автоматично дорівнює втручанням.

**5. Модель виконання політик.** Модель виконання політик визначає, як структурований сигнал ризику  $r_i$  перетворюється на захисну дію  $a_i$ . Її загальне відображення задано рівнянням (2.3). На цьому рівні враховуються профіль захисту особи, режим предметної області, допустима межа втручання, наявність згоди, умови контрольованого перегляду та вимоги приватної перевірки. Однаковий сигнал ризику може породжувати різні дії залежно від політики, віку учасника, ступеня невизначеності й контексту застосування.

Цей рівень завершує ланцюг моделювання. Якщо модель ризику відповідає за те, що система вважає ризиковим, то модель виконання політик відповідає за те, як система має діяти в межах допустимого втручання. Такий поділ потрібний для захисту особи й для захисту самої технології від надмірної централізації. Він дозволяє розрізняти попередження, м’яке обмеження, карантин, блокування, ескалацію та контрольований перегляд як різні дії, а не як різні назви одного й того самого рішення.

Таблиця 2.6 узагальнює призначення кожного рівня та його місце в структурі дисертації.

Табл. 2.6: Рівні моделювання системи AURA

| Рівень                    | Призначення                                                                                  | Деталізація |
|---------------------------|----------------------------------------------------------------------------------------------|-------------|
| Системна модель           | межі системи, ролі, довірені області, інформаційні потоки, місце криптографічного контуру    | розділ 2    |
| Модель події повідомлення | подання повідомлення як події з учасниками, часом, контактом, історією та предметним режимом | розділ 3    |
| Модель локального стану   | контактна пам'ять, пам'ять розмови, часові закономірності, латентні ознаки впливу            | розділ 3    |
| Модель ризику             | перехід від події та стану до структурованого сигналу $r_i$                                  | розділ 3    |
| Модель виконання політик  | перехід від сигналу $r_i$ до захисної дії $a_i$ з урахуванням політик                        | розділ 4    |

Це розмежування важливе для наукової строгості роботи. Якщо розділ 3 трактувати лише як опис класифікатора, зникає головна новизна: повідомлення оцінюється як подія в системі, а не як окремий рядок тексту. Якщо розділ 4 змішати з розділом 3, втрачається розділення між сигналом ризику та захисною дією. Якщо криптографічний контур розглядати окремо від системної моделі, він стає набором протоколів без пояснення, для чого саме потрібний у середовищі контекстної приватності. Тому розділ 2 задає карту моделей, а наступні розділи послідовно деталізують її складові.

## 2.9. Потік даних: від повідомлення до захисного рішення

Потік даних у запропонованій технології визначає, які сутності можуть перетинати межу між кінцевим пристроєм, сервером і пристроєм опікуна. Саме ця межа відрізняє AURA від централізованих систем контролю вмісту.

У звичайному сценарії опрацювання повідомлення відбувається так.

1. Учасники взаємодії проходять автентифікацію і встановлюють криптографічно захищений канал відповідно до рівнів, розглянутих у розділах 5–6.
2. Сервер маршрутизує шифротекст і службові дані доставки, але не отримує відкритого тексту повідомлення.
3. Кінцевий пристрій адресата локально розшифровує повідомлення і формує подію  $e_i$  за рівнянням (2.1).
4. Середовище AURA оновлює локальний стан взаємодії  $H_i$  і формує структурований сигнал ризику  $r_i$ .
5. Метод прийняття рішень з урахуванням політик перетворює  $r_i$  на дію  $a_i$ : дозвіл, попередження, м'яке обмеження, ескалацію, карантин, блокування або контрольований перегляд.
6. Якщо політика вимагає нагляду, на пристрій опікуна передається лише захищений блок даних через канал, непрозорий для сервера.
7. Для перевірки якості та підзвітності можуть формуватися приватні записи перевірки, які не містять повного відкритого тексту і підлягають окремим правилам мінімізації.

У цьому потоці є три різні класи даних. Перший клас – відкритий текст повідомлення, історія розмови і проміжні стани оцінювання ризику. Вони залишаються на кінцевому пристрої. Другий клас – шифротекст, службові дані доставки, ідентифікатори черг та підтвердження, потрібні для роботи системи. Їх бачить сервер, але вони не повинні розкривати зміст повідомлення. Третій клас – захисні сигнали нагляду, що можуть передаватися пристроєм опікуна у зашифрованому вигляді та залишаються непрозорими для сервера.

Така організація реалізує принцип приватності за будовою. Відкритий текст не вилучається з кінцевого пристрою для того, щоб система могла виконати захисну функцію. Натомість захисна функція переноситься до тієї частини системи, де відкритий текст уже доступний легітимно. Це не усуває всіх ризиків. Службові дані, часова активність, розміри повідомлень і сам факт взаємодії можуть залишатися видимими серверу або мережевому спостерігачу. Тому

робота не стверджує повного приховування метаданих, а формулює окрему межу: контекстні рішення AURA не потребують серверного доступу до відкритого тексту та повної історії розмови.

## 2.10. Життєвий цикл захисного рішення

Потік даних показує, які відомості переміщуються між областями системи. Проте для системного моделювання цього недостатньо. Потрібно також описати життєвий цикл захисного рішення: як подія входить до середовища AURA, як вона впливає на локальний стан, як виникає сигнал ризику, як цей сигнал набуває статусу дії і як зберігаються межі перевірки. У цій роботі життєвий цикл розглядається як послідовність станів, а не як одноразовий виклик засобу класифікації.

Узагальнено життєвий цикл захисного рішення має такі етапи.

1. **Надходження події.** Повідомлення надходить на кінцевий пристрій у зашифрованому вигляді, після чого локально розшифровується в межах звичайної роботи захищеного каналу.
2. **Формування події в контексті.** Відкритий текст поєднується з дозволеними локальними ознаками: станом контакту, часовою ознакою, історією розмови, предметним режимом і політикою.
3. **Оновлення локального стану.** Середовище AURA оновлює представлення взаємодії. На цьому етапі важлива мінімізація: стан має містити не більше, ніж потрібно для подальшого оцінювання.
4. **Оцінювання ризику.** На основі події та локального стану формується структурований сигнал  $r_i$ , що не зводиться до однієї мітки.
5. **Перевірка невизначеності.** Система оцінює, чи достатньо підстав для дії, чи потрібне м'яке попередження, додаткове спостереження за динамікою або відмова від втручання.
6. **Застосування політики.** Сигнал ризику переходить до простору дій лише через політику. Саме політика визначає, чи буде дія локальною, чи вимагатиме контрольованого перегляду.

7. **Виконання дії.** Система виконує дозвіл, попередження, м'яке обмеження, карантин, блокування, ескалацію або контрольований перегляд у межах дозволеного втручання.
8. **Формування матеріалу перевірки.** Для відтворюваності можуть створюватися приватні або знеособлені записи, що дають змогу перевірити якість рішення без масового розкриття змісту.

Цей життєвий цикл має дві важливі властивості. Перша властивість полягає в тому, що рішення не виникає безпосередньо з відкритого тексту. Воно проходить через стан, модель ризику і політику. Друга властивість полягає в тому, що кожний етап має власну межу відповідальності. Помилка класифікації, помилка політики, помилка криптографічного протоколу і помилка реалізації не повинні змішуватися в одну нечітку категорію «система помилилася». Саме таке розділення дає змогу будувати подальшу відтворювану перевірку в розділі 8.

Табл. 2.7: Життєвий цикл захисного рішення в середовищі AURA

| Етап                     | Сутність переходу                                                | Основна межа                 |
|--------------------------|------------------------------------------------------------------|------------------------------|
| Надходження події        | шифротекст доставляється і розшифровується на кінцевому пристрої | криптографічна               |
| Формування події         | повідомлення поєднується з дозволеними контекстними ознаками     | приватність                  |
| Оновлення стану          | локальна пам'ять взаємодії змінюється без передавання серверу    | мінімізація                  |
| Оцінювання ризику        | формується сигнал $r_i$                                          | метод оцінювання             |
| Перевірка невизначеності | визначається підстав для дії                                     | достатність межа впевненості |



| Етап                           | Сутність переходу                                 | Основна межа        |
|--------------------------------|---------------------------------------------------|---------------------|
| Застосування політики          | сигнал переходить до простору дій                 | політика            |
| Виконання дії                  | система виконує дозволену захисну дію             | допустиме втручання |
| Формування матеріалу перевірки | створюються матеріали для відтворюваного контролю | підзвітність        |

## 2.11. Уніфікована модель загроз

Модель загроз потрібна для того, щоб твердження різних рівнів технології не змішувалися. У роботі розрізняються криптографічні властивості протоколів, властивості локального виконання політик, властивості каналу нагляду, властивості програмної реалізації та властивості експериментального оцінювання. Кожна з них має різну природу доказовості.

Розглядаються такі класи супротивника:

- **мережевий супротивник**, який може перехоплювати, повторювати, затримувати або модифікувати мережеві повідомлення в межах криптографічної моделі.
- **напівчесний або частково скомпрометований сервер**, який виконує маршрутизацію і зберігання, але не повинен отримувати відкритий текст повідомлень або захисних сигналів.
- **супротивник із доступом до серверної бази даних**, для якого окремо аналізуються межі парольної автентифікації, OPRF-секретів і серверних записів.
- **майбутній квантовий супротивник**, пов'язаний із моделлю «накопичити зараз, розшифрувати згодом» [10], що мотивує постквантове підсилення на основі стандартизованих примітивів [11].
- **супротивник на кінцевому пристрої**, який виходить за межі гарантій локального контекстного захисту за умови повної компрометації пристрою.

- **супротивник конфігурації політик**, який може зловживати надмірно широкими правилами нагляду або невиправданими порогами втручання.

Для кожного класу супротивника фіксується межа відповідальності технології. Криптографічні протоколи мають забезпечувати секретність і автентифікацію в межах визначених моделей. Середовище AURA має виконувати локальне оцінювання ризику без передавання відкритого тексту серверу. Канал нагляду має не відкривати захисний блок даних серверу. Експериментальна перевірка має оцінювати якість рішень на визначених корпусах і не повинна перетворюватися на твердження про абсолютну безпеку людини.

Окремо фіксується припущення про цілісність кінцевого пристрою. Якщо пристрій особи повністю скомпрометовано, відкритий текст повідомлень, локальна історія взаємодії та стани AURA можуть бути доступні супротивнику незалежно від криптографічної якості мережевого протоколу. У цьому випадку наскрізне шифрування не захищає відкритий текст після розшифрування на самому пристрої. Тому захист від повної компрометації кінцевого пристрою не є твердженням цієї дисертації. Робота розглядає локальне середовище виконання політик за припущення, що пристрій здатний коректно виконувати довірену частину програмної логіки.

Так само окремо фіксується межа постквантового твердження. Постквантове підсилення спрямоване передусім на довготривалу конфіденційність узгоджених ключів і повідомлень у моделі майбутнього квантового супротивника. Воно не перетворює слабкий пароль на сильний секрет і не усуває ризики, пов'язані з локальним відкритим текстом, політиками або людською поведінкою. Для парольної автентифікації межі класичної та квантової стійкості формуються окремо в розділі 5.

Властивості протокольного рівня, такі як секретність сесійного ключа, автентифікація та кореспонденція подій, підтверджуються символічною верифікацією засобами Tamarin та ProVerif [12, 13] у межах заданої моделі. Така верифікація не охоплює повну цілісність кінцевого пристрою, побічні канали реалізації, соціальне тлумачення ризикової взаємодії або клінічне підтвердження захисних рішень. Це не недолік моделі, а необхідне розмежування типів доказовості.

## 2.12. Типологія інференційних загроз цифрового середовища

Назва дисертації прямо вказує на інференційні загрози цифрового середовища, тому їх потрібно розглядати не як загальне тло, а як окремий об'єкт моделювання. Інференційна загроза відрізняється від прямого витoku тим, що небажані відомості або ризиковий вплив виникають не з одного явно небезпечного повідомлення, а з поєднання фрагментів контексту. Такі загрози особливо складні для захищених комунікаційних середовищ, оскільки сервер не повинен читати повідомлення, але особа все одно може потребувати захисту після локального розшифрування.

У цій роботі доцільно виділити щонайменше сім класів інференційних загроз, які обґрунтовують потребу в середовищі AURA.

1. **Накопичувальне виведення.** Ризик формується через послідовне накопичення малих ознак, кожна з яких окремо не є достатньою підставою для втручання. Прикладом є поступове уточнення розкладу, місця перебування, емоційного стану або соціального оточення особи.
2. **Поведінкове профілювання.** Супротивник або ризиковий контакт використовує повторюваність реакцій, час відповіді, готовність погоджуватися або уникати тем для побудови уявлення про вразливість особи.
3. **Зміщення довіри.** Ризик виникає тоді, коли контакт поступово переносить взаємодію з нейтрального режиму до режиму особистої залежності, секретності або підпорядкування.
4. **Приховане перенесення каналу.** Учасника схиляють перейти до іншого середовища взаємодії, де слабші правила захисту, немає нагляду або неможливо відтворити історію ризикового впливу.
5. **Наростання примусу.** Окремі повідомлення можуть виглядати нейтрально, але їхня повторюваність, тональність і часовий тиск утворюють послідовність примусу.
6. **Використання вразливого стану.** Контакт реагує на ознаки страху, самотності, розгубленості, залежності або потреби в підтримці та змінює поведінку так, щоб посилити вплив.

7. **Зловживання захисною політикою.** Небезпека може виникати не лише від контакту, а й від надмірно широких правил нагляду, коли захист перетворюється на непропорційне розкриття приватного змісту.

Ці загрози мають спільну рису: їх неможливо надійно охопити лише криптографічним протоколом. Криптографія може приховати повідомлення від сервера і мережевого спостерігача, але вона не визначає, чи є послідовність уже розшифрованих повідомлень ризиковою для адресата. Так само їх неможливо надійно охопити лише списком заборонених висловів. У багатьох випадках небезпека полягає не у слові, а в послідовності, повторюваності, зміні ролей і створенні залежності.

Табл. 2.8: Типологія інференційних загроз і місце AURA в їх опрацюванні

| <b>Клас загрози</b>      | <b>Чому недостатньо окремого повідомлення</b>                 | <b>Вимога до AURA</b>        |
|--------------------------|---------------------------------------------------------------|------------------------------|
| Накопичувальне виведення | кожна ознака слабка, але сукупність утворює чутливий висновок | підтримання локального стану |
| Поведінкове профілювання | ризик виникає з реакцій і повторюваності, а не лише зі змісту | часові та контактні ознаки   |
| Зміщення довіри          | зміна характеру стосунку відбувається поступово               | пам'ять стану контакту       |
| Перенесення каналу       | небезпечним є намір вивести розмову за межі захисту           | виявлення переходу режиму    |

| <b>Клас загрози</b>           | <b>Чому недостатньо окремого повідомлення</b>                  | <b>Вимога до AURA</b>          |
|-------------------------------|----------------------------------------------------------------|--------------------------------|
| Наростання примусу            | окремі вимоги можуть бути слабкими, послідовність створює тиск | оцінювання ескалації           |
| Використання вразливого стану | ризик від стану особи та динаміки відповіді                    | обережна модель невизначеності |
| Зловживання політикою         | небезпека виникає від надмірного захисного втручання           | межі дій і приватна перевірка  |

Запропонована типологія не претендує на вичерпний опис усіх соціальних небезпек цифрового середовища. Її призначення інше: задати технічно придатну і науково обережну основу для моделювання інформаційного ризику. Саме тому у формалізації використовуються подія, стан, сигнал ризику, невизначеність і політика, а не категорії клінічного діагностування або моральної оцінки.

Для захисту дітей така типологія має окрему вагу. Дитина може не розпізнати поступове зміщення довіри, не оцінити небезпеку перенесення розмови в інше середовище або не мати достатньої автономії для опору повторюваному тиску. Водночас сама наявність дитини в системі не виправдовує необмежений нагляд. Тому модель AURA має поєднати підвищену чутливість до накопичувальних і поведінкових сигналів із суворими межами розкриття приватного змісту.

Таким чином, інференційна загроза в роботі є не додатковим прикладом, а причиною, через яку потрібна саме методологія приватного контекстного захисту. Без цієї типології AURA могла б виглядати як ще один засіб локального попередження. З нею AURA постає як середовище, що опрацьовує ризик, який виникає на перетині змісту, історії, ролей, часу, невизначеності й політики.

## 2.13. Критерії коректності системної концепції

Системна концепція має бути не лише описовою, а й нормативною: вона повинна задавати критерії, за якими можна оцінити, чи конкретна реалізація справді належить до запропонованої інформаційної технології. Інакше будь-яка система з локальним попередженням могла б бути названа AURA, навіть якщо вона передає відкритий текст серверу або не має відтворюваної перевірки. Тому в роботі вводяться критерії коректності системної концепції.

Перший критерій – *коректність межі відкритого тексту*. Відкритий текст повідомлення та повна локальна історія не повинні передаватися серверу як умова контекстного оцінювання. Якщо реалізація вимагає такого передавання, вона може бути корисною як інша технологія контролю, але не відповідає концепції AURA.

Другий критерій – *достатність локального контексту*. Система має використовувати не лише поточний текст, а й дозволені представлення стану взаємодії. Якщо контекст відсутній, метод зводиться до позаконтекстної класифікації і втрачає центральну наукову ознаку розділу 3.

Третій критерій – *розділення сигналу і дії*. Оцінювання ризику має завершуватися структурованим сигналом, а не безпосереднім остаточним втручанням. Дія повинна виникати через політику, оскільки політика враховує межі допустимого втручання, профіль захисту, невизначеність і режим контролюваного перегляду.

Четвертий критерій – *мінімізація та обмеження зберігання*. Локальний стан не повинен перетворюватися на необмежену базу приватних розмов. Будь-яке представлення має мати призначення, межу часу життя і зв'язок з методом оцінювання.

П'ятий критерій – *відтворюваність перевірки*. Якість системи не може бути заявлена лише декларативно. Вона має перевірятися через визначені корпуси, сценарії, пороги допуску, журнали перевірки та повторювані процедури.

Шостий критерій – *відповідність твердження виду доказу*. Якщо властивість доводиться формально, треба зазначити модель і припущення. Якщо властивість вимірюється, треба зазначити корпус, процедуру і межі узагальнення. Якщо властивість є архітектурною, треба показати, як вона підтримується потоками даних і межами ролей.

Табл. 2.9: Критерії коректності системної концепції AURA

| Критерій                 | Зміст                                                        | Порушення                                               |
|--------------------------|--------------------------------------------------------------|---------------------------------------------------------|
| Межа відкритого тексту   | відкритий текст не передається серверу для оцінювання ризику | серверний контроль змісту                               |
| Достатність контексту    | оцінювання враховує локальний стан взаємодії                 | класифікація одного повідомлення                        |
| Розділення сигналу і дії | $r_i$ формується до застосування політики                    | автоматичне втручання без політики                      |
| Мінімізація стану        | локальні представлення мають призначення і межі зберігання   | неконтрольоване накопичення приватного змісту           |
| Відтворюваність          | якість перевіряється повторюваними процедурами               | декларативна якість без перевірки                       |
| Відповідність доказу     | кожне твердження має власний тип обґрунтування               | змішування формального доказу, вимірювання і реалізації |

Ці критерії не замінюють методів наступних розділів, але визначають, яким вимогам вони мають відповідати. Розділ 3 має задовольнити критерії достатності контексту, мінімізації та структурованості сигналу. Розділ 4 має задовольнити критерій розділення сигналу і дії. Розділи 5–6 мають забезпечити криптографічний контур, який підтримує межу відкритого тексту. Розділи 7–8 мають показати, що контрольований перегляд і перевірка якості не руйнують приватність.

## 2.14. Концептуальна матриця наукової новизни

Оскільки робота виконується на здобуття наукового ступеня доктора наук, концепція не повинна зводитися до опису реалізації. Вона має породжувати систему наукових результатів, кожен із яких має власний об'єкт, метод, межу доказовості та місце в дисертації. Тому вже в розділі 2 доцільно зафіксувати концептуальну матрицю майбутньої наукової новизни.

У цій матриці AURA виконує роль центрального узгоджувального рівня. Вона не замінює криптографічні протоколи, не підміняє експериментальну оцінку і не перетворюється на медичну систему. Її наукова функція полягає в тому, що вона об'єднує контекстне оцінювання інформаційного ризику, політики захисних дій, межу відкритого тексту, контрольований перегляд і відтворювану перевірку в одну інформаційну технологію.

Табл. 2.10: Концептуальна матриця наукової новизни дисертації

| № | Науковий результат                                | Сутність новизни                                                                                                        | Розділ |
|---|---------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|--------|
| 1 | Методологія захисту контекстної приватності особи | приватність, контекстність, підзвітність і межова доказовість подані як єдина система вимог                             | 2      |
| 2 | Модель повідомлення в контексті                   | події повідомлення розглядається не як ізольований текст, а як подія з учасниками, історією, часом і предметним режимом | 2–3    |



| № | Науковий результат                                    | Сутність новизни                                                                                         | Розділ |
|---|-------------------------------------------------------|----------------------------------------------------------------------------------------------------------|--------|
| 3 | Модель локального стану взаємодії                     | контекст підтримується на кінцевому пристрої без серверного накопичення відкритого тексту                | 3      |
| 4 | Метод контекстної оцінки інформаційного ризику        | ризик подається як структурований сигнал з класом, рівнем, впевненістю, джерелами ознак і невизначеністю | 3      |
| 5 | Метод прийняття захисних рішень з урахуванням політик | сигнал ризику відокремлено від дії, а втручання визначається політикою і допустимими межами              | 4      |
| 6 | Криптографічний контур для приватного виконання AURA  | автентифікація, узгодження сесії та захист повідомлень підтримують межу відкритого тексту                | 5–6    |
| 7 | Метод каналу нагляду, непрозорого для сервера         | допомога уповноваженого учасника можлива без серверного розкриття захисного змісту                       | 7      |

| № | Науковий результат                                         | Сутність новизни                                                                                            | Розділ |
|---|------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|--------|
| 8 | Інформаційна технологія відтворюваною приватною перевіркою | реалізація, з вимірювання, допуск до випуску та матеріали перевірки поєднані в контрольований життєвий цикл | 8      |

Ця матриця не є остаточним формулюванням пунктів наукової новизни для вступу. Її призначення полягає в іншому: вона показує, що кожний наступний розділ має не лише описову, а й результативну функцію. Розділ 3 не повинен бути оглядом засобів аналізу повідомлень, бо його результатом має бути метод контекстної оцінки ризику. Розділ 4 не повинен дублювати розділ 3, бо його результатом має бути метод переходу від ризику до дії. Розділи 5–7 не є додатковими криптографічними вставками, а забезпечують межі приватного виконання AURA. Розділ 8 має показати інформаційну технологію як відтворюваний комплекс, а не як одиничний програмний дослід.

Водночас така матриця дисциплінує межі тверджень. Якщо певний результат заявляється як метод, він має містити модель, вхідні та вихідні сутності, припущення процедури застосування і спосіб перевірки. Якщо результат заявляється як інформаційна технологія, він має показати взаємодію методів, програмну реалізацію, відтворювані перевірки і межі застосування. Якщо результат заявляється як удосконалення протоколу, він має бути пов’язаний із формальною моделлю або принаймні з чітко окресленим криптографічним припущенням.

Отже, другий розділ задає не лише загальну ідею, а й каркас майбутньої новизни. Це важливо для докторського рівня роботи: наукові результати мають бути пов’язані між собою методологічно, а не розміщені поруч як набір окремих розробок. У запропонованій структурі таким об’єднавчим центром є середовище AURA як середовище виконання політик захисту контекстної приватності.

## 2.15. Відображення «проблема – метод»

Таблиця 2.11 робить зв'язок між проблемами приватного контекстного захисту та запропонованими методами явним. Вона задає наскрізну логіку роботи від аналізу стану проблеми до реалізації інформаційної технології.

Табл. 2.11: Відображення проблем приватного контекстного захисту на запропоновані методи

| Проблема                                                                                                   | Метод / рівень захисту                                               | Розділ                                                                     |
|------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------|----------------------------------------------------------------------------|
| Передавання пароля або еквівалентного паролю матеріалу серверу                                             | постквантово-посилена OPAQUE-автентифікація                          | 5                                                                          |
| Майбутнє квантове розшифрування перехоплених повідомлень у моделі «накопичити зараз – розшифрувати згодом» | гібридне посилене постквантово-наскрізне шифрування                  | 6                                                                          |
| Дилема безпеки за шифрування, серверний відкритого суперечить приватності                                  | контекстної наскрізного коли контроль тексту                         | середовище AURA: контекстна оцінка ризику та рішення з урахуванням політик |
| Позаконтекстна класифікація окремого повідомлення дає слабкі та нестійкі рішення                           | метод контекстної оцінки інформаційного ризику із підтриманням стану | 3                                                                          |
| Необхідність контрольованого перегляду без розкриття відкритого тексту серверу                             | метод каналу нагляду, неprozорого для сервера                        | 7                                                                          |

| Проблема                                        | Метод / рівень захисту | Розділ                  |
|-------------------------------------------------|------------------------|-------------------------|
| Потреба доказовості, інформаційна технологія, 8 | та оцінювання          | з                       |
| підзвітності                                    | якості                 | контрольованим допуском |
| відтворюваності                                 | до випуску та приватна | перевірка               |

З цієї таблиці випливає роль розділу 2 як сполучної ланки. Він не замінює окремих методів, але визначає, чому ці методи мають розроблятися разом. Без OPAQUE і наскрізного шифрування середовище виконання політик не матиме достатньої криптографічної основи. Без AURA криптографічно захищене середовище залишиться сліпим до ризикового інформаційного впливу після розшифрування повідомлення на пристрої. Без каналу нагляду, непрозорого для сервера, захисні рішення для вразливих учасників будуть або локальними без можливості допомоги, або централізованими з розкриттям приватного змісту. Без відтворюваного оцінювання технологія не матиме науково контрольовано межі якості.

## 2.16. Межі тверджень

Для докторської роботи критично важливо не змішувати архітектурну пропозицію, формальний доказ, експериментальну оцінку та інженерну реалізацію. Таблиця 2.12 розмежовує, що саме стверджується, яким є статус доказовості і в якому розділі це розгортається.

Табл. 2.12: Межі тверджень дисертації за рівнем доказовості

| Твердження / властивість                   | Статус доказовості                           | Розділ |
|--------------------------------------------|----------------------------------------------|--------|
| Пароль не передається формальна модель і 5 | серверу у відкритому або перевірка протоколу |        |
| еквівалентному паролю                      |                                              |        |
| вигляді                                    |                                              |        |

| Твердження / властивість                                                                                                                                                                        | Статус доказовості | Розділ |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------|--------|
| Стійкість до перебору формальна модель з 5<br>словника поза взаємодією явними операційними<br>із сервером за компрометації межами<br>бази даних без секрету<br>opr_f_seed у класичній<br>моделі |                    |        |
| Постквантове підсилення формальна модель 5–6<br>узгодження сесії в межах в окреслених<br>гібридної конструкції припущеннях                                                                      |                    |        |
| Секретність і кореспонденція символічна верифікація 6<br>активної моделі наскрізного в обмеженій моделі<br>шифрування                                                                           |                    |        |
| Локальність відкритого тексту архітектурний інваріант і 2–4, 8<br>для контекстного оцінювання реалізаційна перевірка<br>ризиків                                                                 |                    |        |
| Серверна непрозорість каналу проєктне обґрунтування, 7<br>нагляду тести і відтворювані<br>матеріали наскрізної<br>перевірки                                                                     |                    |        |
| Якість контекстних захисних експериментальна 3–4, 8<br>рішень оцінка з контрольованим<br>допуском на<br>кураторських і<br>синтетичних корпусах                                                  |                    |        |
| Інженерна реалізованість та програмний комплекс і 8<br>інтеграція технології відтворювані перевірки                                                                                             |                    |        |

| Твердження / властивість                                                                                                                                   | Статус доказовості               | Розділ |
|------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------|--------|
| Не клінічне або психологічне підтвердження, абсолютний захист, повне приховування всіх метаданих, цілісність повністю скомпрометованого кінцевого пристрою | поза межами тверджень дисертації | —      |

Це розмежування виконує не лише обмежувальну, а й конструктивну функцію. Воно дозволяє сильніше формулювати ті твердження, які справді підтримуються відповідним типом доказу. Формальна верифікація має застосовуватися до протоколів, а не до соціального змісту ризику. Експериментальне оцінювання має застосовуватися до якості контекстних рішень, а не до секретності криптографічного ключа. Реалізаційна перевірка має підтверджувати інтеграцію та відтворюваність, але не повинна видаватися за повний математичний доказ безпеки всієї системи.

Саме тому AURA у дисертації подається не як універсальний засіб захисту людини від будь-якої інформації, а як середовище виконання політик контекстної приватності в окресленій моделі. Така постановка зберігає наукову строгість і водночас залишає достатньо простору для практичного застосування в захищених цифрових комунікаційних середовищах, зокрема у сценаріях захисту дітей та інших вразливих осіб.

## Висновки до розділу 2

У розділі розроблено концепцію інформаційної технології захисту контекстної приватності особи на основі середовища виконання політик AURA. Обґрунтовано головну тезу роботи: контекстний захист має виконуватися локально, підтримувати стан взаємодії та перетворювати структурований сигнал ризику в захисну дію з урахуванням політик, а криптографічні методи мають створювати межу, у якій це можливо без серверного доступу до відкритого тексту повідомлень.

Запропоновано формальне подання події повідомлення, сигналу ризику та захисної дії, визначено архітектурні інваріанти AURA, методологічні засади побудови технології, понятійну модель контекстної приватності, системні ролі,

довірені області та класи даних. Описано п'ятирівневу архітектуру AURA/Ecliptix, сформульовано рівні моделювання системи, розкрито потік даних від повідомлення до захисного рішення, життєвий цикл захисного рішення, уніфіковану модель загроз і типологію інференційних загроз цифрового середовища. Показано, що криптографічні рівні, середовище контекстного оцінювання, канал нагляду, непрозорий для сервера, і реалізаційний рівень мають розглядатися як частини єдиної інформаційної технології.

Окремо розмежовано межі тверджень дисертації та побудовано концептуальну матрицю наукової новизни. Формальні властивості протоколів, експериментальна якість контекстних рішень, серверна непрозорість каналу нагляду та інженерна реалізованість мають різні типи доказовості. Це розмежування задає науково коректну рамку для наступних розділів, у яких послідовно розробляються метод контекстної оцінки інформаційного ризику, метод прийняття захисних рішень, криптографічний захисний контур, канал нагляду та інформаційна технологія AURA/Ecliptix.

## **Розділ 3**

# **Метод контекстної оцінки інформаційного ризику**

**3.1. Повідомлення як подія в контексті, а не ізольований текст**

**3.2. Контактна пам'ять**

**3.3. Пам'ять розмови**

**3.4. Часові закономірності, повторюваність та ескалація**

**3.5. Латентні стани маніпуляції (операціоналізація)**

**3.6. Доменні модулі ризику**

**3.7. Формування структурованого сигналу ризику**

Результатом методу є структурований сигнал ризику, що інтегрує контактну пам'ять, пам'ять розмови, часову динаміку та доменний контекст і слугує входом для прийняття рішень з урахуванням політик (розділ 4). *[Розкрити формалізацію та структуру сигналу ризику.]*



## **Висновки до розділу 3**

*[Висновки до розділу 3.]*

## **Розділ 4**

# **Метод прийняття рішень контекстної безпеки з урахуванням політик**

- 4.1. Перетворення сигналу ризику в захисну дію**
- 4.2. Простір рішень системи обміну повідомленнями**
- 4.3. Опрацювання невизначеності**
- 4.4. Профіль захисту учасника та доменний режим**
- 4.5. Приватний аудиторський запис**
- 4.6. Критерії якості з контрольованим допуском до випуску**

Прийняття рішень доповнюється критеріями якості з контрольованим допуском до випуску зі статусами PASS, FAIL, INSUFFICIENT\_SUPPORT та BLOCKED, що формалізують умови допуску захисної логіки до використання (методологію оцінювання розгорнуто в розділі 8). *[Розкрити критерії.]*

## **Висновки до розділу 4**

*[Висновки до розділу 4.]*



## Розділ 5

### Метод

# постквантово-посиленої OPRQUE-автентифікації

**5.1. Постановка задачі та модель загроз автентифікації**

**5.2. Архітектура трьохповідомленнєвого протоколу**

**5.3. Реєстрація та зв'язування ідентифікатора й контексту**

**5.4. Гібридне DH/KEM-узгодження сесії**

**5.5. Операційна модель `opr_f_seed` і межі квантового впливу**

**5.6. Формальний аналіз і межі доведення**

**5.7. Реалізація, простежуваність специфікації та вимір швидкодії**

Метод супроводжується еталонною реалізацією на Rust із простежуваністю специфікації до коду, перевіркою безпеки пам'яті, обнуленням секретів та

відтворюваними вимірюваннями швидкодії примітивів і протоколу. *[Розкрити кількісні результати.]*

## **Висновки до розділу 5**

*[Висновки до розділу 5.]*

## **Розділ 6**

# **Метод гібридного постквантового наскрізного шифрування**

**6.1. Постановка та гібридний криптографічний корінь**

**6.2. Класична автентифікація сторін**

**6.3. Подвійний «храповик» з КЕМ-підсиленням кроком**

**6.4. Захист метаданих**

**6.5. Межі: повторне відтворення, відкот стану та  
пропущені ключі**

**6.6. Формальні докази та узгодження тверджень**

Формальні гарантії подано в окреслених межах: активна модель ProVerif розряджає три первинні твердження та одну додаткову перевірку кореспонденції чесного повідомлення, а навантажувальні перевірки явно не належать до тверджень роботи. *[Звірити з журналами перевірки та статтею перед фіналом.]*

## **6.7. Груповий протокол в окреслених межах**

### **Висновки до розділу 6**

*[Висновки до розділу 6.]*





## **Розділ 7**

# **Метод серверно-сліпого каналу нагляду**

**7.1. Постановка задачі: приватний контрольований перегляд**

**7.2. Згода, контрольована пристроєм дитини**

**7.3. Активний зв'язок між дитиною та опікуном**

**7.4. Виділення парного ключа для кожного пристрою**

**7.5. Маршрутизація непрозорого вмісту та роль сервер**

**7.6. Життєвий цикл підтвердження, відкликання та очищення**

**7.7. Межі: повторне відтворення, час життя, відмова в обслуговуванні та межа приватності**

**7.8. Наскрізний сценарій та відтворюваний доказ**

Метод ілюструється наскрізним сценарієм від надання згоди до відкликання, що супроводжується відтворюваним інтеграційним тестом і документом перевірки

з точною командою та очікуваним результатом (див. розділ 8 і додатки). *[Зафіксувати наскрізний доказ.]*

## **Висновки до розділу 7**

*[Висновки до розділу 7.]*



## **Розділ 8**

# **Інформаційна технологія AURA/Ecliptix та експериментальна перевірка**

**8.1. Архітектура реалізації**

**8.2. Інтерфейси міжмовної взаємодії (FFI)**

**8.3. Інтеграція каналу нагляду та межа приватності  
пошуку**

**8.4. Керування наборами даних**

**8.5. Оцінювання з контрольованим допуском до випуску  
та приватний аудит**

**8.6. Експериментальна перевірка**

**8.7. Реєстр відтворюваних матеріалів та відтворюваніс**

**8.8. Обмеження та межі застосування**

визначає межі застосування й напрями подальших досліджень. *[Розкрити обмеження.]*

## **Висновки до розділу 8**

*[Висновки до розділу 8.]*

# Висновки

У дисертації розв’язано науково-прикладну проблему приватного контекстного захисту учасників цифрової комунікації від ризикових інформаційних впливів в умовах наскрізного шифрування та постквантового переходу. Одержано такі основні результати.

1. Запропоновано архітектуру захисту контекстної приватності на основі середовища виконання політик AURA, у якій оцінювання ризику, рішення з урахуванням політик, постквантово-посилена автентифікація, гібридне наскрізне шифрування та серверно-сліпий канал нагляду є рівнями однієї інформаційної технології без перенесення відкритого тексту на сервер. *[Уточнити після розділу 2.]*
2. Розроблено метод контекстної оцінки інформаційного ризику, що враховує контакт, історію розмови, часову динаміку, повторюваність та латентні стани маніпуляції і формує структурований сигнал ризику. *[Розділ 3.]*
3. Удосконалено метод прийняття захисних рішень з урахуванням політик, опрацюванням невизначеності, профілем захисту особи та приватним аудитом. *[Розділ 4.]*
4. Удосконалено метод постквантово-посиленої OPAQUE-автентифікації з гібридним DH/KEM-узгодженням сесії та операційним розмежуванням `prf_seed`, що підтверджено формально та реалізаційно. *[Розділ 5.]*
5. Удосконалено метод гібридного постквантового наскрізного шифрування з KEM-підсиленням кроком «храповика» та формальними доказами в окреслених межах. *[Розділ 6.]*
6. Запропоновано метод серверно-сліпого каналу нагляду, що передає захисні

сигнали пристрою опікуна без розкриття відкритого тексту серверу. [Розділ 7.]

7. Удосконалено модель меж компрометації та методологію приватного аудиту й оцінювання з контрольованим допуском до випуску зі статусами PASS, FAIL, INSUFFICIENT\_SUPPORT, BLOCKED. [Розділи 2, 8.]

8. Розроблено інформаційну технологію AURA/Ecliptix, яка реалізує запропоновані методи з відтворюваною перевіркою. [Розділ 8.]

**Практичне значення.** *[Узагальнити придатність результатів та впровадження.]*

**Обмеження та напрями подальших досліджень.** *[Чесно зазначити межі: відсутність клінічного підтвердження, класичний характер підписів, окреслені межі формальних доказів; окреслити подальші напрями.]*



# Бібліографія

- [1] Sarah Scheffler and Jonathan Mayer. SoK: Content moderation for end-to-end encryption. *Proceedings on Privacy Enhancing Technologies (PoPETs)*, 2023(2):403–429, 2023. doi: <https://doi.org/10.56553/popets-2023-0060>.
- [2] Harold Abelson, Ross Anderson, Steven M. Bellovin, Josh Benaloh, Matt Blaze, Jon Callas, Whitfield Diffie, Susan Landau, Peter G. Neumann, Ronald L. Rivest, Jeffrey I. Schiller, Bruce Schneier, Vanessa Teague, and Carmela Troncoso. Bugs in our pockets: The risks of client-side scanning. *Journal of Cybersecurity*, 10(1):tyad020, 2024. doi: <https://doi.org/10.1093/cybsec/tyad020>.
- [3] Seny Kamara, Mallory Knodel, Emma Llansó, Greg Nojeim, Lisa Qin, Dhanaraj Thakur, and Caitlin Vogus. Outside looking in: Approaches to content moderation in end-to-end encrypted systems. Technical report, Center for Democracy & Technology (CDT), 2021. arXiv:2202.04617. <https://arxiv.org/abs/2202.04617>.
- [4] Stanislaw Jarecki, Hugo Krawczyk, and Jiayu Xu. OPAQUE: An asymmetric PAKE protocol secure against pre-computation attacks. In *Advances in Cryptology – EUROCRYPT 2018*, volume 10822 of *LNCS*, pages 456–486. Springer, 2018. doi: [https://doi.org/10.1007/978-3-319-78372-7\\_15](https://doi.org/10.1007/978-3-319-78372-7_15).
- [5] Daniel Bourdreux, Hugo Krawczyk, Kevin Lewi, and Christopher A. Wood. The OPAQUE augmented password-authenticated key exchange (aPAKE) protocol. Technical Report RFC 9807, IRTF (CFRG), Informational, 2025. <https://www.rfc-editor.org/info/rfc9807>.

- [6] Trevor Perrin and Moxie Marlinspike. The double ratchet algorithm. Signal Specifications, Revision 1, 2016. <https://signal.org/docs/specifications/doubleratchet/>.
- [7] Ehren Kret and Rolfe Schmidt. The PQXDH key agreement protocol. Signal Specifications, Revision 3, 2023. <https://signal.org/docs/specifications/pqxdh/>.
- [8] Richard Barnes, Benjamin Beurdouche, Raphael Robert, Jon Millican, Emad Omara, and Katriel Cohn-Gordon. The messaging layer security (MLS) protocol. Technical Report RFC 9420, IETF, 2023. doi: <https://doi.org/10.17487/RFC9420>.
- [9] Paul Grubbs, Jiahui Lu, and Thomas Ristenpart. Message franking via committing authenticated encryption. In *Advances in Cryptology – CRYPTO 2017*, volume 10403 of *LNCS*, pages 66–97. Springer, 2017. doi: [https://doi.org/10.1007/978-3-319-63697-9\\_3](https://doi.org/10.1007/978-3-319-63697-9_3).
- [10] Michele Mosca. Cybersecurity in an era with quantum computers: Will we be ready? *IEEE Security & Privacy*, 16(5):38–41, 2018. doi: <https://doi.org/10.1109/MSP.2018.3761723>.
- [11] National Institute of Standards and Technology. Module-lattice-based key-encapsulation mechanism standard. Technical Report FIPS 203, NIST, 2024. doi: <https://doi.org/10.6028/NIST.FIPS.203>.
- [12] Simon Meier, Benedikt Schmidt, Cas Cremers, and David Basin. The TAMARIN prover for the symbolic analysis of security protocols. In *Computer Aided Verification (CAV 2013)*, volume 8044 of *LNCS*, pages 696–701. Springer, 2013. doi: [https://doi.org/10.1007/978-3-642-39799-8\\_48](https://doi.org/10.1007/978-3-642-39799-8_48).
- [13] Bruno Blanchet. Modeling and verifying security protocols with the applied pi calculus and ProVerif. *Foundations and Trends in Privacy and Security*, 1(1–2):1–135, 2016. doi: <https://doi.org/10.1561/33000000004>.

# Додатки

## Додаток А. Реєстр відтворюваних матеріалів і перевірок

*[Заповнити після фіксації версій репозиторіїв.]*

## Додаток Б. Формальні моделі та фрагменти специфікації

*[Додати лістинги/посилання на моделі.]*

## Додаток В. Додаткові таблиці вимірювань швидкодії

*[Додати таблиці вимірювань швидкодії.]*

## Додаток Г. Акти впровадження та копії публікацій

*[Долучити акти впровадження та перші сторінки публікацій за наявності.]*